Specyfikacja Techniczna
API Gateway – wersja 2.4

Opis architektury, endpointow, autoryzacji i schema danych
dla systemu zarzadzania zamowieniami

Projekt:	OrderFlow Platform
Wersja API:	v2.4.1 (stable)
Status:	Zatwierdzony do produkcji
Data:	15 Marca 2025
Autor:	Zespol Platform Engineering
Klasyfikacja:	Wewnetrzna / Confidential

1. PRZEGLAD SYSTEMU

API Gateway stanowi centralny punkt wejscia dla wszystkich zewnetrznych i wewnetrznych klientow systemu OrderFlow. Bramka realizuje uwierzytelnianie, autoryzacje, rate limiting, logowanie, routing do mikrouslug oraz transformacje requestow i responsow. Architektura opiera sie na modelu sidecar proxy (Envoy) z planszczyzna kontroli Istio.

Wersjonowanie API

API Gateway obsluguje rownolegla prace wersji v1 (deprecated), v2 (current) i v2.4 (stable). Wersja v1 zostanie wycofana 1 Lipca 2025. Wszystkich klientow prosimy o migracjê do v2.4.

1.1 Stos technologiczny

Komponent	Technologia	Wersja	Uwagi
Proxy / Gateway	Envoy Proxy	1.29	Konfiguracja via xDS API
Service Mesh	Istio	1.21	mTLS, Traffic Mgmt, Observability
Autoryzacja	OPA (Open Policy A	0.62	Polityki w jezyku Rego
Autentykacja	Keycloak	23.0	OAuth 2.0, OIDC, SAML 2.0
Rate Limiting	Redis Cluster	7.2	Algorytm token bucket
Obserwabilnosc	OpenTelemetry + Ja	1.46	Distributed tracing
Logowanie	Vector + Loki + Gra	0.35	Structured JSON logs
Rejestry API	Kong Manager	3.5	Portal dev + API catalog

1.2 Topologia wdrozenia

Gateway wdrozony jest w trzech strefach dostepnosci (AZ-A, AZ-B, AZ-C) klastra Kubernetes (EKS 1.29). Minimalna liczba replik wynosi 3 (po jednej na AZ), maksymalna – 20 (HPA, target CPU 70%). Ruch wychodzacy do mikrouslug odbywa sie wylacznie po sieci wewnetrznej VPC przez mTLS.

2. AUTENTYKACJA I AUTORYZACJA

2.1 Obsługiwane metody autentykacji

- OAuth 2.0 / OIDC – dedykowany dla aplikacji webowych i mobilnych (Authorization Code + PKCE)
- API Key – dla integracji B2B i systemow zewnetrznych (naglowek: X-API-Key)
- mTLS (Mutual TLS) – dla komunikacji serwis-serwis wewnatrz sieci VPC
- JWT Bearer Token – token podpisany RSA-256, wazny 15 minut, refresh token wazny 30 dni
- Basic Auth – wylacznie w srodowisku deweloperskim (dev.api.orderflow.pl), zablokowany na prod

2.2 Scopes i uprawnienia

Scope	Opis	Dozwolone met	Dotyczy
orders:read	Odczyt zamowien	GET	Klienci B2C, B2B, admini
orders:write	Tworzenie/edycja zamowien	POST, PUT, PATC	Klienci B2C zalogowani
orders:delete	Anulowanie zamowien	DELETE	Admini, support L2
products:read	Odczyt katalogu	GET	Publiczny (bez tokenu)
products:write	Zarzadzanie produktami	POST, PUT, DELE	Merchantci, admini
payments:read	Historia platnosci	GET	Wlasciciel konta
payments:write	Inicjowanie platnosci	POST	Klienci zalogowani
admin:*	Pelny dostep admin	Wszystkie	Rola ADMIN_PLATFORM

2.3 JWT – struktura tokenu

Kazdy JWT wystawiony przez Keycloak zawiera nastepujace claims wymagane przez Gateway:

- sub (string) – UUID uzytkownika lub klienta B2B
- scope (array<string>) – lista przyznanych scopow
- tenant_id (string) – identyfikator dzierzawcy (multitenant)
- roles (array<string>) – role RBAC przypisane w Keycloak
- iat / exp (int) – timestamps wystawienia i wygasniecia (exp = iat + 900s)
- jti (UUID) – unikalny identyfikator tokenu, sprawdzany pod katem replay attacks w Redis

3. ENDPOINTY – ZASOBY ZAMOWIEN

Wszystkie endpointy dostepne sa pod bazowym URL: https://api.orderflow.pl/v2/

Metoda	Endpoint	Opis	Auth wymagan	Rate lim
GET	/orders	Lista zamowien (paginated)	orders:read	100/min
POST	/orders	Nowe zamowienie	orders:write	20/min
GET	/orders/{id}	Szczegoly zamowienia	orders:read	200/min
PATCH	/orders/{id}	Aktualizacja statusu	orders:write	50/min
DELETE	/orders/{id}	Anulowanie	orders:delete	10/min
GET	/orders/{id}/items	Pozycje zamowienia	orders:read	200/min
POST	/orders/{id}/payment	Inicjuj platnosc	payments:write	5/min
GET	/orders/{id}/tracking	Sledzenie przesylki	orders:read	300/min

3.1 Parametry zapytania – GET /orders

Parametr	Typ	Wymagany	Domyslnie	Opis
page	integer	Nie	1	Numer strony (1-based)
per_page	integer	Nie	20	Wynikow na strone (max 100)
status	enum	Nie	all	Filtr: new|processing|shipped|delivered|cancell
from_date	date (ISO 8601)	Nie	30 dni temu	Data poczatkowa
to_date	date (ISO 8601)	Nie	dzis	Data koncowa
sort_by	string	Nie	created_at	Pole sortowania
sort_dir	enum	Nie	desc	asc | desc
q	string	Nie	–	Fulltext search w nr zamowienia i adresie

4. SCHEMA DANYCH – ORDER OBJECT

Ponizej przedstawiono kompletny schemat obiektu zamowienia zwracanego przez API. Schema zdefiniowana jest w jezyku JSON Schema Draft-07 i opublikowana rowniez w rejestrze schematow pod adresem: https://schema.orderflow.pl/order/v2.4

Pole	Typ JSON	Wymagane	Opis	Przykladowa
id	string (UUID)	TAK	Unikalny ID zamowienia	ord_9f3a2c...
status	string (enum)	TAK	Status zamowienia	processing
customer_id	string (UUID)	TAK	ID klienta	cust_7b2e...
tenant_id	string	TAK	ID dzierzawcy	pl_main
items	array<OrderItem	TAK	Pozycje zamowienia	[...]
totals	object	TAK	Sumy (netto, VAT, brutto, PLN)	{"net":120.00,...}
shipping	object	NIE	Dane dostawy i adres	{"method":"paczkomat",...}
payment	object	NIE	Metoda i status platnosci	{"method":"blik",...}
created_at	string (ISO 8601)	TAK	Data utworzenia	2024-11-15T14:23:00Z
updated_at	string (ISO 8601)	TAK	Data modyfikacji	2024-11-16T08:11:22Z
metadata	object	NIE	Dodatkowe pola niestandardov	{"source":"mobile_app"}

4.1 OrderItem – schema

Pole	Typ	Opis
product_id	string (UUID)	ID produktu z katalogu
sku	string	SKU z systemu WMS
name	string	Nazwa produktu (snapshot z chwili zamowienia)
quantity	integer	Ilosc sztuk (min: 1, max: 9999)
unit_price_net	number	Cena jednostkowa netto (PLN)
vat_rate	number	Stawka VAT: 0.0, 0.05, 0.08 lub 0.23
line_total_gross	number	Wartosc brutto pozycji (obliczana przez API)

5. OBSŁUGA BLEDOW

API stosuje standardowe kody HTTP i zwraca body bledow w formacie RFC 7807 (Problem Details for HTTP APIs). Kazdy blad zawiera pola: type, title, status, detail, instance.

HTTP Statu	Kod wewnetrzny	Opis	Przykladowa przyczyna
400	ERR_VALIDATION	Niepoprawny request	Brakujace pole, zly typ danych
401	ERR_UNAUTHORIZE	Brak lub nieważny token	Token wygasl, brak naglowka Authorization
403	ERR_FORBIDDEN	Brak uprawnien	Niewystarczajace scope
404	ERR_NOT_FOUND	Zasob nie istnieje	Order ID nie znaleziony
409	ERR_CONFLICT	Konflikt stanu	Zamowienie juz anulowane
422	ERR_UNPROCESSAE	Blad biznesowy	Brak towaru, platnosc odrzucona
429	ERR_RATE_LIMITED	Przekroczony rate limit	X-RateLimit-Retry-After w naglowku
500	ERR_INTERNAL	Blad serwera	Nieoczekiwany wyjatek w uslugach
503	ERR_UNAVAILABLE	Usluga niedostepna	Restart, deployment, circuit breaker

5.1 Naglowki rate limitingu

- X-RateLimit-Limit: maksymalna liczba requestow w oknie czasowym
- X-RateLimit-Remaining: pozostale requesty w biezacym oknie
- X-RateLimit-Reset: timestamp UTC (epoch) resetu licznika
- X-RateLimit-Retry-After: sekundy do czekania przy statusie 429
- Algorytm: Token Bucket – refill co 1 sekunde, burst do 20% powyzel limitu

6. WEBHOOKS

API Gateway oferuje mechanizm webhookow pozwalajacy na asynchroniczne powiadamianie systemow zewnetrznych o zdarzeniach w zamowieniach. Webhook wysylany jest jako HTTP POST na skonfigurowany endpoint klienta z podpisem HMAC-SHA256 w naglowku X-OrderFlow-Signature.

Typ zdarzenia	Opis	Payload – pola kluczowe
order.created	Nowe zamowienie zlozono	order_id, status, totals, created_at
order.status_changed	Zmiana statusu	order_id, old_status, new_status, changed_at
order.payment_confirr	Platnosc potwierdzona	order_id, payment_id, amount, method
order.shipped	Zamowienie wysylane	order_id, tracking_number, carrier, estimated_delivery
order.delivered	Zamowienie dostarczone	order_id, delivered_at, recipient_confirmed
order.cancelled	Zamowienie anulowane	order_id, reason, cancelled_by, refund_status
order.refund_issued	Zwrot wystawiony	order_id, refund_id, amount, method

6.1 Retry policy

- Brak odpowiedzi lub HTTP 5xx: retry z exponential backoff: 5s, 30s, 5min, 30min, 2h, 12h
- HTTP 4xx (oprocz 429): brak retry – zdarzenie uznane za dostarczone
- Timeout per proby: 10 sekund
- Maksymalna liczba prób: 6 (po 6 niepowodzeniach – zdarzenie w kolejce dead-letter)
- Rejestr dostarczen dostepny w Developer Portal: https://developers.orderflow.pl

7. CHANGELOG

Wersja	Data	Zmiany
v2.4.1	2025-03-15	Poprawka: race condition w rate limiterze (issue #4421)
v2.4.0	2025-01-10	Nowe: webhook order.refund_issued; cache odpowiedzi GET /products 60s TTL
v2.3.2	2024-11-20	Poprawka: nieprawidlowy vat_rate=0.0 traktowany jako null
v2.3.0	2024-09-05	Nowe: pole metadata w Order Object; filtr q w GET /orders
v2.2.0	2024-06-01	Nowe: mTLS dla serwis-serwis; migracja rate limit na Redis Cluster
v2.0.0	2024-01-15	Wersja major: nowe schema, JWT z jti, OPA do autoryzacji